

АТАКУЕМЫЕ СРЕДСТВА ИСКУССТВЕННОГО ИНТЕЛЛЕКТА: РЕГЛАМЕНТАЦИЯ ПРОЦЕССА УПРАВЛЕНИЯ УЯЗВИМОСТЯМИ ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ, ИСПОЛЬЗУЕМОГО В ИНФОРМАЦИОННО- ТЕЛЕКОММУНИКАЦИОННЫХ СИСТЕМАХ

В.П. Лось, Д.А. Нархов, Я.С. Федюков, В.В. Молокеедова, Н.С. Тимошевский

В данной статье рассматривается актуальная проблема организации процесса управления уязвимостями программного обеспечения средств искусственного интеллекта, применяемых в информационно-телекоммуникационных системах и функционирующих в условиях реализации сетевых атак. Обоснована необходимость применения системного подхода, включающего стадии мониторинга, анализа уязвимостей, определения методов их устранения и последующего контроля эффективности принятых мер. Предлагается структуризация управления уязвимостями на основе ключевых этапов, каждый из которых тщательно проработан для достижения максимального снижения рисков. Отмечается, что подход позволит минимизировать вероятность реализации атак и обеспечить надежное функционирование систем. Показана важность учета специфических уязвимостей, характерных для средств искусственного интеллекта. Особое внимание уделяется тестированию обновлений программного обеспечения, как важному элементу управления уязвимостями, направленному на выявление ранее неизвестных уязвимостей и анализу потенциальных механизмов их эксплуатации в информационно-телекоммуникационных системах.

Ключевые слова: уязвимости, программное обеспечение, искусственный интеллект, информационная безопасность, информационно-телекоммуникационные системы, управление, меры

Введение

За период 2021-2025 годов был зафиксирован скачок популярности средств искусственного интеллекта (ИИ) и, как следствие, быстрый рост количества фактов их применения в информационно-телекоммуникационных системах (ИТКС), следовательно, радикально изменилась концепция защищенности инфраструктуры [1]. Вместе с тем, повышение сложности используемых программных средств и применение современных сетевых протоколов формируют широкий спектр уязвимостей, потенциально пригодных для реализации атак [2-5]. С другой стороны, программное обеспечение, реализующее функции ИИ, в высокой степени зависит от библиотек машинного обучения, внешних фреймворков и репозиториев, обусловленных модульной архитектурой современных средств [6]. Таким образом, значительно усложняется процесс оценки защищенности ИТКС и увеличивается время реагирования на обнаруженные уязвимости. В результате

формируется сложная и динамичная экосистема программных зависимостей, а границы обеспечения безопасности размываются. В свою очередь, отсутствие конкретизированных требований к регламентации процедуры управления уязвимостями в ИТКС, использующих средства ИИ, усугубляет проблему и подчеркивает ее актуальность [7-8]. При этом, существующие методы зачастую не учитывают специфику рассматриваемой предметной области, а также не сформирована единая регламентационная основа, позволяющая системно идентифицировать, классифицировать, оценивать и устранять бреши в системе защиты информации. Поэтому настоящее исследование осуществлено с целью выработки рекомендаций по регламентации управления уязвимостями программного обеспечения средств ИИ (СИИ) для достижения минимизации рисков, связанных с эксплуатацией дефективных элементов кода и сопутствующих компонентов. Создание

такой организационно-правовой защиты позволяет повысить уровень доверия к системам, обеспечить соответствие требованиям обеспечения информационной безопасности и создать основу для комплексной защищенности инфраструктурных элементов.

Специфика уязвимостей программного обеспечения искусственного интеллекта

В ходе анализа сценариев реализации атак на ИТКС, включающих в свой состав СИИ, стало ясно, что одной из оптимальных организационно-технических мер по защите информации является внедрение процесса управления уязвимостями программного обеспечения (ПО) в организации.

ПО СИИ представляет собой сложный продукт, имеющий не только традиционные уязвимости, но и подверженный рискам реализации атак, актуальных только для них, например, отравление обучающих данных, атаки уклонения, извлечение модели и обратная инженерия. Подобные атаки нарушают базовые свойства информации: конфиденциальность, доступность и целостность, что позволяет злоумышленникам получить несанкционированный доступ к данным, компрометировать или блокировать запросы от пользователей к моделям.

Следовательно, процедуры выявления и устранения уязвимостей должны входить в обязательный перечень мер защиты информации на этапах функционирования не только искусственного интеллекта, но и программного обеспечения.

Жизненный цикл ИИ представляет собой иерархическую и итеративную структуру, в которой ключевым этапом является тестирование и оценка защищенности.

Уязвимости, выявленные на этапе тестирования или в ходе эксплуатации, требуют не просто исправления, а пересмотра всех предыдущих этапов жизненного цикла.

Таким образом, процесс управления уязвимостями в ИИ-системах получается динамичным, адаптивным и ориентированным на постоянное повышение защищенности.

На основе анализа, становится очевидно, что особое значение приобретает управление конфигурацией и составом используемых компонентов.

В отличие от привычного ПО, где контроль версий уже является стандартной практикой, для искусственного интеллекта на первое место выдвигается необходимость ведения актуального реестра всех элементов системы, то есть учет используемых библиотек, моделей и зависимостей. Отсутствие прозрачности в составе СИИ создает условия для несанкционированного ввода уязвимых или вредоносных средств, что особенно критично на этапах сбора данных и разработки.

Процедура контроля обновлений нуждается в распространении на все используемое программное обеспечение. Установка свежих компонентов без уязвимостей является одной из основополагающих мер нейтрализации выявленных уязвимостей.

Стоит отметить, что обновления подлежат тестированию на отсутствие недеklarированных возможностей. Это требование становится особо актуальным в случаях использования программного обеспечения с открытым кодом, поскольку факт подмены реализуется гораздо проще, в сравнении с проприетарными продуктами.

В случаях, когда устранение уязвимости не представляется возможным, предусматривается использование компенсирующих мер. Для программного обеспечения СИИ в виде решения проблемы могут выступать: валидация и санитизация данных для обучения, ограничения экспозиции модели, применение механизмов состязательного обучения, мониторинг аномалий в поведении модели.

Регламент управления уязвимостями программного обеспечения средств ИИ

На основе полученных данных был разработан регламент управления уязвимостями СИИ в организации, структура и основные ступени которого представлен на рис. 1.



Рис. 1. Этапы процесса управления уязвимостями [7]

На стадии выявления уязвимостей и оценки их эксплуатации необходимо учитывать, что количество информационных источников кратно увеличивается, ибо помимо привычных ресурсов, таких как БДУ ФСТЭК России, сайты разработчиков и NVD, добавляются публикации в научных и исследовательских ресурсах, библиотеки машинного обучения, аномалии в поведении ИИ-моделей, учет рисков связанных с цепочками обновлений ПО.

Оценка применимости включает не только наличие подверженного уязвимости средство в инфраструктуре, но и наличие условий для их эксплуатации атаками на искусственный интеллект.

В ходе оценки уязвимостей выявляются факторы, напрямую влияющие на целостность решений модели, вследствие чего повышаются риски утечки конфиденциальных данных и реализации возможности несанкционированного влияния на обучающие данные.

Расчет критичности стоит проводить с учетом частоты технического применения средств, оценки потенциального этического, юридического и операционного их влияния.

В процессе определения методов и приоритетов устранения уязвимостей обычно применяется классический подход, который предполагает комплексную установку

обновлений. Но в случае использования ПО ИИ необходимо учитывать специфические методы, когда осуществляется: повторное или дообучение модели на очищенных и проверенных данных, изменение экспозиции модели с помощью ограничения доступа непроверенного сетевого трафика, валидация запросов, снижающих их частоту.

Приоритеты устранения следует устанавливать с помощью уровня критичности и степени доверия к модели.

Стадия устранения уязвимостей включает тестирование полученных обновлений, позволяющее убедиться в: отсутствии нарушений логики, этической характеристики, наличии скрытых уязвимостей, и после осуществить комплексную проверку системы на корректность, ее устойчивость к атакам.

В случаях, когда невозможно полное устранение, реализуются компенсирующие меры, точно направленные на ИИ. Например, проводится мониторинг аномалий в выводе модели, обеспечивается полное логирование журналов средства с целью аудита, выявления и последующего анализа инцидентов.

На ступени контроля устранения уязвимостей осуществляется повторное сканирование ИИ-компонентов, тестирование их устойчивости к атакам, оценка качества и

этичности решений после внесения изменений. В условиях выявления неэффективности примененных мер проводится переоценка уязвимости и корректировка стратегии реагирования на инциденты информационной безопасности. Также полученные данные используются для совершенствования внутреннего регламента управления уязвимостями и формирования эффективной и устойчивой организационно-технической культуры безопасного применения ИИ в ИТКС.

Завершив рассмотрение основных ступеней регламента управления уязвимостями ПО ИИ, отдельное внимание стоит уделить процессу, интегрируемому в стадию устранения уязвимостей – тестированию обновлений, по целому ряду тестов проводимых перед внедрением исправлений или новых версий компонентов.

Наибольшую важность имеют третий, четвертый и пятые тесты:

- T003, антивирусный контроль, позволяет нам своевременно определить наличие вредоносов в обновляемых компонентах реализованного СИИ. Особую актуальность он получает при интеграции сторонних решений, включая предобученные модели, библиотеки машинного обучения. Контроль осуществляется с использованием сигнатурных и поведенческих методов анализа, что повышает вероятность обнаружения известных и не встречавшихся ранее угроз;

- T004, поиск опасных конструкций, явно указывает на потенциальные компрометирующие элементы, а также деструктивный контент в составе ИИ. Наибольшую важность он получает в контексте выявления скрытых угроз;

- T005, мониторинг активности обновлений безопасности в среде тестирования, который предусматривает необходимость проведение следующих мероприятий:

- анализ результатов выполнения системных вызовов обновленного программного обеспечения, позволяющий своевременно определить возможное деструктивное поведение программного обеспечения по отношению к среде функционирования;

- анализ (получаемых и отправляемых обновленным программным, программно-аппаратным средством) сетевых пакетов, который наиболее важен в случаях локального развертывания моделей ИИ. В частности, он позволяет нам определить факт того, что средство несанкционированно не осуществляет обмен информацией с неизвестными источниками.

- анализ состава файловой системы (до и после установки обновления программного, программно-аппаратного средства) позволяет детектировать или обнаружить факт модификации конфигурационных файлов СИИ (к отслеживаемым объектам можно отнести веса, метрики теплоты).

В случае осуществления деструктивных воздействий в отношении чувствительных данных может вызвать как отказ в обслуживании модели, так и “галлюцинации”, подразумевается обобщенное название факта обмана и подмены. Поскольку обнаружить наступление второго последствия порой весьма затруднительно, накапливаются скрытые ошибки, которые приводят к постепенной деградации модели. В результате, при отсутствии резервных копий или сохраненных обученных состояний, владельцу ИИ-системы придется проходить процесс машинного обучения с чистого листа, что влечет за собой значительные потери. В случае, если разработчик полностью доверяет модели, проявление галлюцинаций способно также деструктивно воздействовать и на конечного пользователя.

Сигнатурный поиск известных уязвимостей позволяет специалистам по защите информации определять новые и актуальные уязвимости, а следовательно, перестраивать графы потенциальных атак ввиду появления дополнительных опасных факторов.

Только при успешном прохождении всех этапов тестирования, обновление признается безопасным и может быть допущено к внедрению.

Однако, по причине ограниченности ресурсов организации, далеко не каждая уязвимость может быть устранена. В данном случае на первый план выступает проблема определения приоритетов.

В случае устранения уязвимости, эксплуатация которой предусмотрена в ходе атаки, граф перестраивается, поскольку между соответствующими вершинами теряется связь, что предоставляет шанс администратору безопасности сменить приоритеты что, позволяет целенаправленно распределять ресурсы на устранение критичных уязвимостей, минимизируя потенциальный ущерб, повышая общую устойчивость ИТКС к атакам.

Предложенный регламент управления уязвимостями СИИ отражает специфику используемых технологий, учитывает технические и этико-правовые аспекты применения в ИТКС.

Заключение

Анализ современных угроз, направленных на программное обеспечение искусственного интеллекта в ИТКС, демонстрирует рост как количества, так и сложности атак, эксплуатирующих как традиционные уязвимости, так и специфические слабости. В подобных условиях регламент становится не просто рекомендацией, а обязательным элементом обеспечения информационной безопасности.

В рамках проведенного исследования была сформирована научно подкрепленная основа для регламентации процесса управления уязвимостями программного обеспечения искусственного интеллекта, направленная на минимизацию рисков, связанных с эксплуатацией дефектов кода и компонентов. Предлагаемый подход охватывает пять этапов жизненного цикла управления уязвимостями с учетом специфики рассматриваемой прикладной области. Предложенный регламент обеспечивает соответствие требованиям законодательства в области защиты информации, повышает уровень доверия к ИИ-системам и создает предпосылки для построения комплексной и устойчивой к

современным угрозам защиты инфраструктурных элементов.

Особый интерес в контексте управления уязвимостями вызывает создание специализированного средства автоматизации, совмещающего функции сканирования ИИ-компонентов, оценку критичности, планирование обновлений и мониторинг аномального поведения моделей.

Список литературы

1. AI/ML security in mobile telecommunication networks // Ericsson Mobility Report URL: <https://www.ericsson.com/en/blog/2024/4/ai-ml-security-in-mobile-telecommunication-networks> (дата обращения: 04.12.2025).
2. Банк данных угроз безопасности информации ФСТЭК России // БДУ URL: <https://bdu.fstec.ru/> (дата обращения: 04.12.2025).
3. National Vulnerability Database // NVD URL: <https://nvd.nist.gov/> (дата обращения: 04.12.2025).
4. База знаний MITRE URL: <https://attack.mitre.org/> (дата обращения: 04.12.2025).
5. Common Attack Pattern Enumeration and Classification // CAPEC URL: <https://capec.mitre.org/> (дата обращения: 04.12.2025).
6. MITRE ATLAS (Adversarial Threat Landscape for AI Systems) URL: https://atlas.mitre.org/pdf-files/SAFEAI_Full_Report.pdf (дата обращения: 04.12.2025).
7. Руководство по организации процесса управления уязвимостями в органе (организации): метод. документ // ФСТЭК России. – 2023. – 33 с.
8. Методика тестирования обновлений безопасности в программных, программно-аппаратных средствах: метод. документ // ФСТЭК России. – 2022. – 16 с.

Российский государственный гуманитарный университет
Russian State University for the Humanities

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 17.07.2025

Информация об авторах

Лось Владимир Павлович – д-р воен. наук, профессор, Российский государственный гуманитарный университет, e-mail: alexanderostapenkoias@gmail.com

Нархов Дмитрий Андреевич – аспирант, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Федюков Ярослав Сергеевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Молокоедова Виктория Витальевна – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Тимошевский Никита Сергеевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

ATTACKED ARTIFICIAL INTELLIGENCE TOOLS: REGULATION OF THE VULNERABILITY MANAGEMENT PROCESS OF SOFTWARE USED IN INFORMATION AND TELECOMMUNICATION SYSTEMS

V.P. Los, D.A. Narhov, Y.S. Fedyukov, V.V. Molokoedova, N.S. Timoshevskiy

This article discusses the current problem of the organization of the vulnerability management process of artificial intelligence software used in information and telecommunication systems and operating in the context of network attacks. The necessity of applying a systematic approach, including the stages of monitoring, vulnerability analysis, determination of methods for their elimination and subsequent monitoring of the effectiveness of the measures taken, is substantiated. It is proposed to structure vulnerability management based on key steps, each of which is carefully designed to maximize risk reduction. It is noted that the approach will minimize the likelihood of attacks and ensure reliable operation of the systems. The importance of taking into account the specific vulnerabilities characteristic of artificial intelligence tools is shown. Special attention is paid to testing software updates as a key element of vulnerability management aimed at identifying previously unknown vulnerabilities and analyzing potential mechanisms for their exploitation in information and telecommunications systems.

Keywords: vulnerabilities, software, artificial intelligence, information security, information and telecommunication systems, management, measures.

Information about the authors

Vladimir P. Los – Dr. Sc. (Military), professor, Russian State university for the Humanities, e-mail: alexanderostapenkoias@gmail.com

Dmitry A. Narhov – graduate student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Yaroslav S. Fedyukov – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Viktoriya V. Molokoedova – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Nikita S. Timoshevskiy – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com